# Semana 06 — Excepciones justificadas y control del cambio

Grupo 2 · rol Legal y reporte · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

| | |
|---|---|
| **Curso** | CYBERSEGURIDAD — Ciberseguridad Aplicada |
| **Semana** | 06 de 10 |
| **Fase** | 3 — Defensa y hardening |
| **Grupo** | 2 |
| **Rol** | Legal y reporte |
| **Entrega** | GitHub, carpeta semana_06/ |
| **Corte** | Domingo 23:59 de la semana correspondiente; lo posterior no se corrige. |

## 1 Tu rol en la práctica

Verifica que el alcance y la autorización cubran lo ejecutado, anonimiza la evidencia, revisa la cadena de custodia e integra el informe técnico y el resumen ejecutivo.

- Revisar que el alcance y la autorización cubran exactamente lo ejecutado, ni más ni menos.
- Anonimizar la evidencia y verificar la cadena de custodia de cada archivo entregado.
- Integrar informe técnico y resumen ejecutivo, y declarar los límites del trabajo.

## 2 Qué aporta este rol al entregable

La versión final del informe y la declaración explícita de lo que no se pudo verificar.

## 3 Ejemplo paso a paso

El rol Legal decide que excepcion de hardening se acepta y cual no. Una excepcion sin riesgo declarado, responsable y fecha de revision es una puerta abierta.

### 3.1 Registrar el cambio con su motivo

Cada cambio de configuracion entra en un registro con fecha, autor, motivo y vuelta atras. El registro es el que permite reconstruir el estado si algo falla.

```
mkdir -p semana_06/evidencia
printf '%s | sshd | PermitRootLogin no | Grupo 4 | vuelta: copia previa \n' \
  "$(date -u +%FT%TZ)" > semana_06/evidencia/cambios.txt
cp /etc/ssh/sshd_config semana_06/evidencia/sshd_config.bak 2>/dev/null || true
sha256sum semana_06/evidencia/sshd_config.bak \
  > semana_06/evidencia/sshd_config.bak.sha256 2>/dev/null || true
```

### 3.2 Clasificar cada excepcion por riesgo

Se acepta una excepcion solo si el riesgo es bajo, el responsable esta nombrado y hay fecha de revision. Las de riesgo alto no se aceptan: se corrigen.

### 3.3 Comprobar que la excepcion no reabre el hallazgo

Una excepcion se verifica igual que un control: con el mismo comando. Si la excepcion permite el acceso que se queria cerrar, no era una excepcion.

```
sudo sshd -T | grep -E '^(permitrootlogin|passwordauthentication)' \
  | tee semana_06/evidencia/excepcion_ssh.txt
```

### 3.4 Definir la fecha de revision

Toda excepcion caduca. La fecha se escribe en el registro y se revisa aunque nadie la recuerde.

### 3.5 Excepcion, riesgo y decision

**Excepcion, riesgo y decision**

| Excepcion | Riesgo | Responsable | Revision | Decision |
|---|---|---|---|---|
| PasswordAuthentication si en laboratorio | Medio | Grupo 4 | Fin de semana 6 | Rechazada |
| Puerto 22 abierto en lugar de 2222 | Bajo | Grupo 4 | Fin de curso | Aceptada con registro |
| Servicio de base de datos en escucha | Alto | Grupo 4 | Inmediato | Rechazada |
| Sin fail2ban en contenedor | Bajo | Grupo 4 | Fin de semana 7 | Aceptada temporal |

La decision se escribe como aceptada, rechazada o pendiente. "Se vera" no es una decision.

## 4 Qué guardar en el repositorio

Se entrega el registro de cambios, la tabla de excepciones con su decision y la verificacion de que ninguna excepcion reabre el hallazgo.

```
semana_06/
|-- informe.md
|-- auditor.sh
|-- evidencia/
|   |-- cambios.txt
|   |-- excepcion_ssh.txt
|   `-- sshd_config.bak.sha256
`-- README.md
```

- Cada cambio tiene autor, fecha y vuelta atras.
- Cada excepcion tiene responsable y fecha de revision.
- Las excepciones de riesgo alto estan rechazadas.
- La excepcion aceptada se verifico con el mismo comando del auditor.

# 5 Cómo se corrige

| Criterio | Peso |
|---|---|
| Doce controles documentados y verificables | 2,0 |
| Auditor funcional con veredicto por control | 2,0 |
| Política de filtrado correcta y sistema operativo | 2,5 |
| Alertas de Suricata clasificadas y regla propuesta | 2,5 |
| Antes/después comparables y justificación de excepciones | 1,0 |
| **Total** | **10,0** |

- {'Aceptar una excepcion no es ignorar el control': 'queda registrada y con caducidad.'}
- Si no hay copia previa del archivo modificado, el cambio no se aplica.

**Recuerda**

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.